

NovaPay Digital Bank

Zero-Downtime CI/CD Pipeline with Compliance Gates

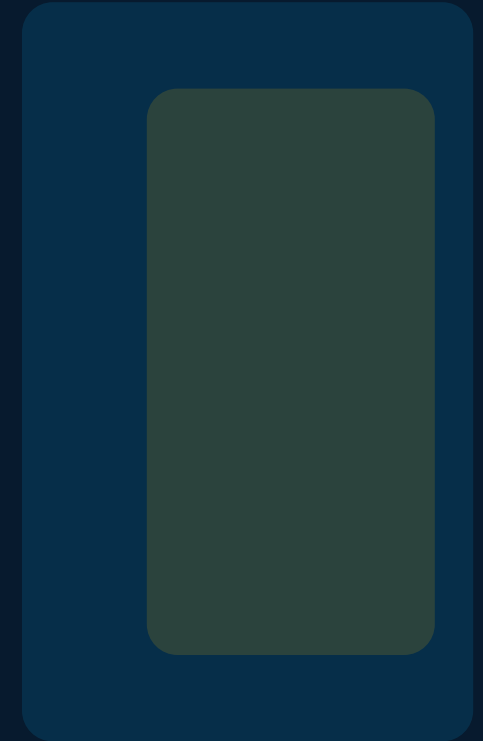
Technology Risk Committee approval pack

Deploy fast

Stay compliant

Never go down

Prepared for TRC review



Current State Risk

Manual release process creates operational, security and audit exposure

NovaPay today

Manual SSH deployments
Fortnightly deployment cadence
4.5-hour MTTR
Zero automated compliance scanning
17 audit non-conformances

Business risk

Manual change + no evidence + slow recovery creates regulatory and operational exposure.

Transformation targets

Deployment cycle



MTTR



Audit gaps



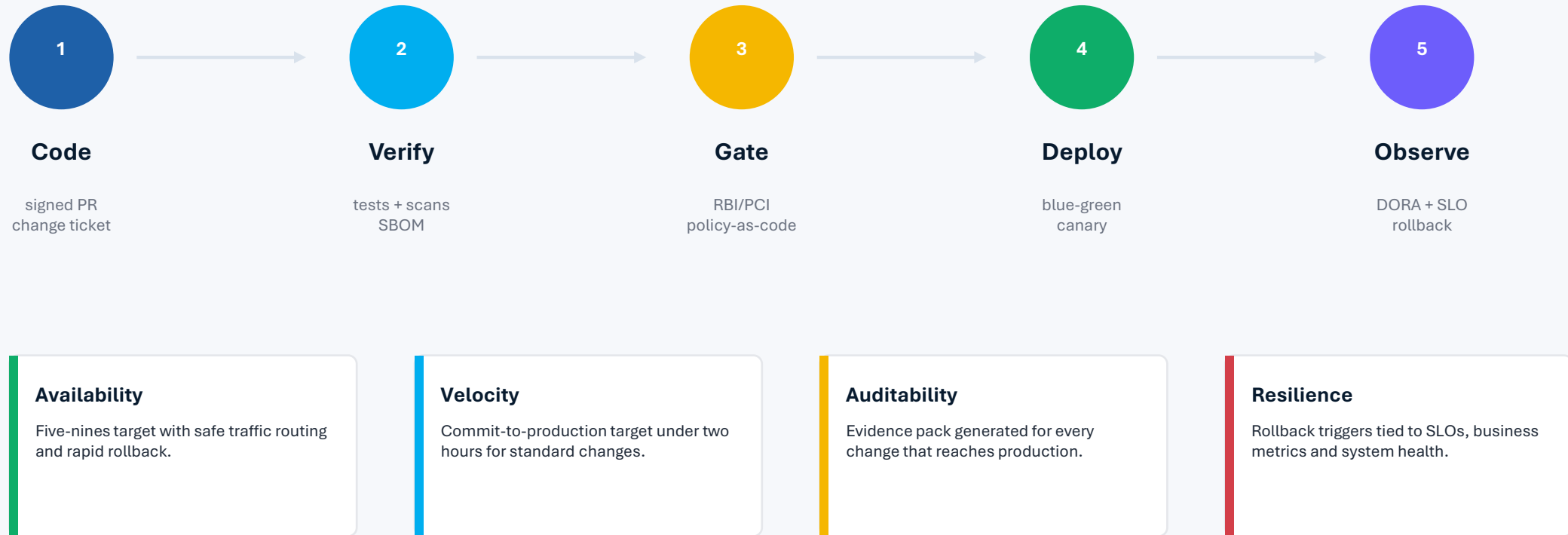
Automated gates



TRC decision: approve the controlled delivery platform that turns release risk into measurable, reversible change.

Target State: Regulated DevSecOps Delivery

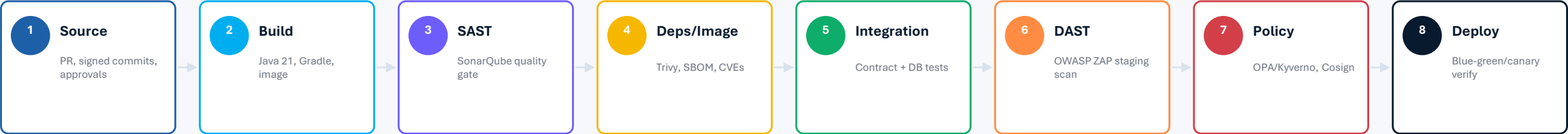
Fast delivery becomes acceptable only when controls are automated and evidence is complete



Outcome: a pipeline that regulators can inspect, engineers can use, and SREs can recover quickly.

Eight-Stage CI/CD Architecture

Each stage produces evidence, gates risk, and reduces blast radius before production



Quality gates run in parallel where possible

Build output feeds SAST, dependency scan and container scan independently; only verified artefacts move into deployment verification.

Gate thresholds

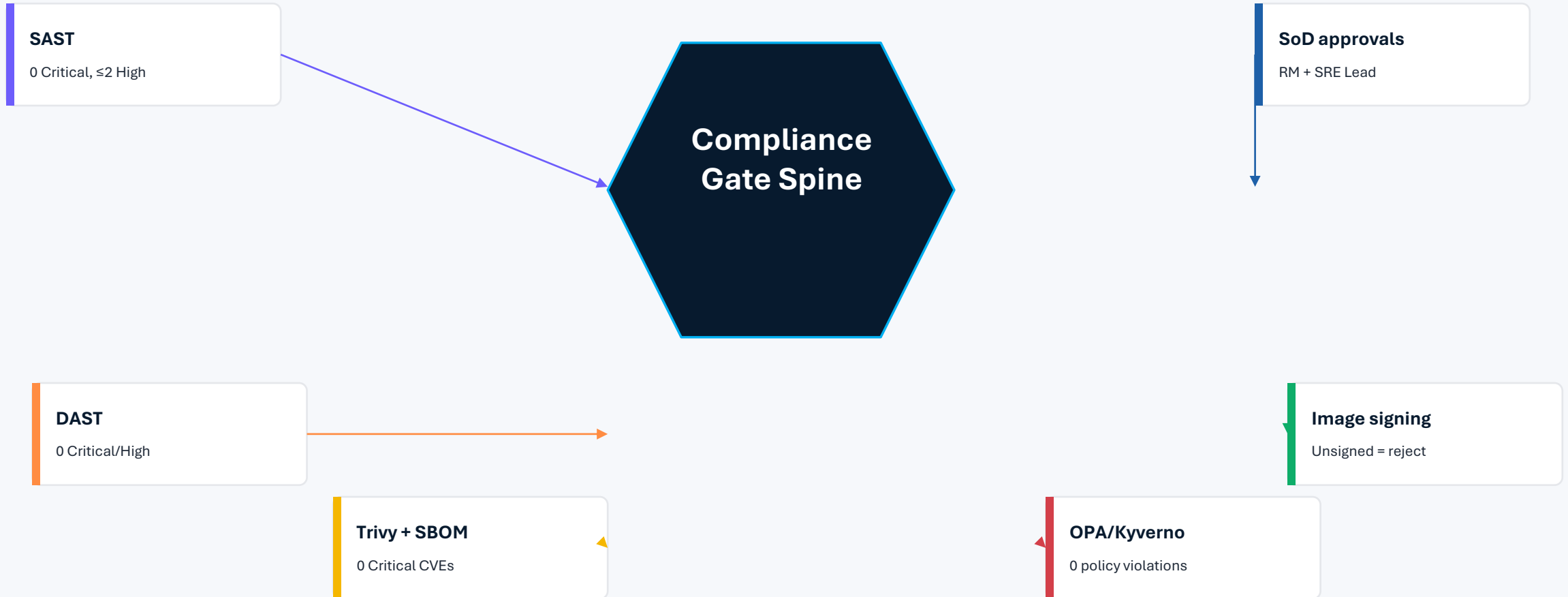
0 Critical SAST/DAST findings
0 Critical CVEs for production
SBOM and image signature required
Policy violations block deployment

Evidence pack

Build logs • scan reports • SBOM • approvals • manifests • metrics • rollback records

Security and Compliance Gates

Automated evidence replaces manual post-release checklists



Failed gates are not failures of the project — they are controls working as designed.

RBI / PCI-DSS Control Mapping

Controls are embedded into pipeline decisions and evidence records

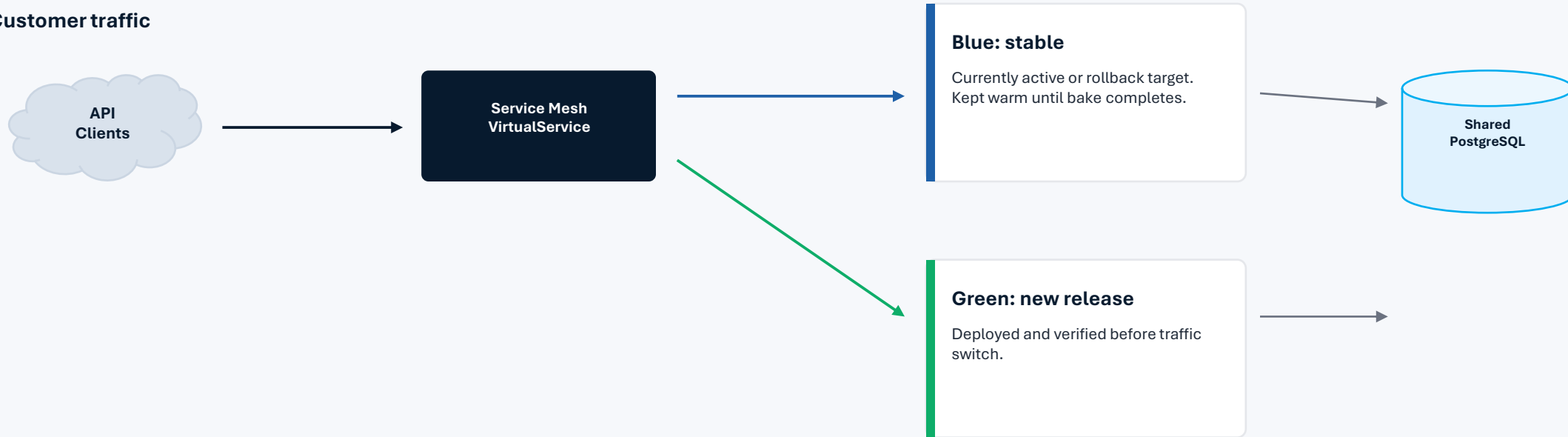
Risk Area	Pipeline Control	Evidence / Decision
Change management	PR approval, change ticket, CAB/dual approval	Approval record + deployment log
Vulnerability management	SAST, DAST, dependency and container scanning	Reports + remediation ticket
Segregation of duties	Developer cannot approve production	Environment approver audit
Audit trail	Immutable evidence pack per release	Commit → image → deploy trace
Data protection	Secrets manager, TLS/mTLS, PII logging checks	Policy result + scan evidence
Third-party risk	SBOM, licence scan, CVE gate	SBOM + licence report
Operational resilience	Canary, rollback, incident playbook	Metrics + rollback record
Availability reporting	SLOs, DORA, deployment dashboard	TRC dashboard summary

Decision rule: production promotion is blocked unless mandatory control evidence exists or a formal time-bound exception is approved.

Blue-Green Deployment Strategy

Full-environment cutover with fast traffic rollback

Customer traffic



Cutover sequence

- Deploy to inactive color
- Verify health/version/synthetic journey
- Drain old traffic
- Switch service mesh route atomically
- Keep previous color warm for rollback

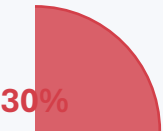
Rollback = route traffic back to previous color in <60 seconds.

Canary Deployment Strategy

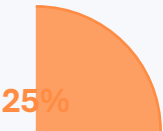
Progressively expose traffic only while health score remains acceptable



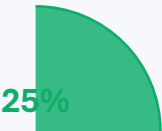
Automated health score



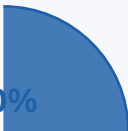
Errors



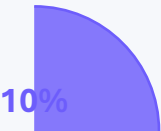
Latency



Transactions



Resources



Synthetic

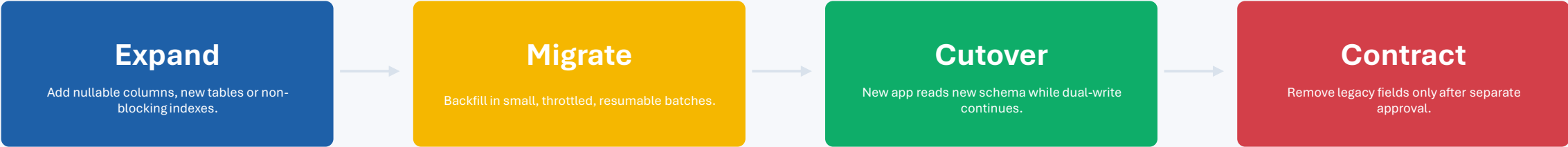
Decision

95–100 promote
85–94 observe
70–84 pause
<70 rollback

Canary limits blast radius while real production signals validate the release.

Expand-Contract Database Migration

Zero-downtime releases depend on backward-compatible schema changes



Compatibility matrix

Schema state	Old app	New app
Original	Works	Maybe
Expanded	Works	Works
Backfilled	Works	Works
Contracted	Fails	Works

100M+ row controls

Batch size starts at 1,000 • throttle if p99 latency rises >20% • pause if DB CPU >70% or pool >80% • checkpoint every batch • contract is separate change

Rule: blue-green and canary are safe only while old and new app versions both work against the same schema.

Automated Rollback Model

Rollback is a controlled decision engine, not a manual afterthought

Category A — <60 seconds

5xx >5% for 60s
3 health failures
CrashLoopBackOff
DB pool exhausted

Category B — <15 minutes

p99 >2x baseline
error budget burn >10x
payment success -2%
CPU/memory saturation

Category C — manual

customer reports
compliance anomaly
external dependency
gradual degradation

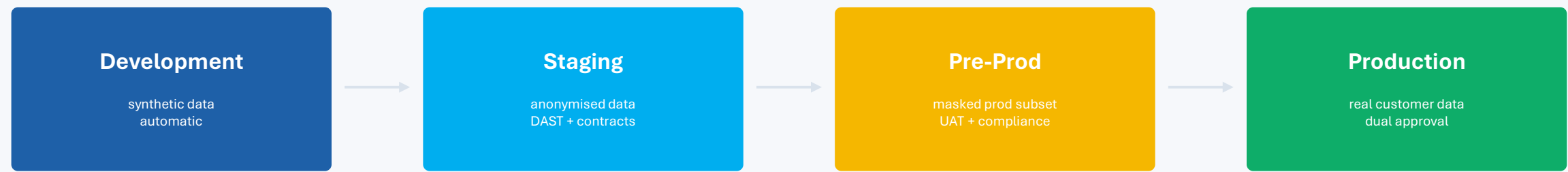
Rollback flow



Post-rollback verification: stable version, health, p99, error rate, payment success, DB pool, queues and alert status.

Environment Promotion Workflow

Same artefact, different configuration, increasing evidence confidence



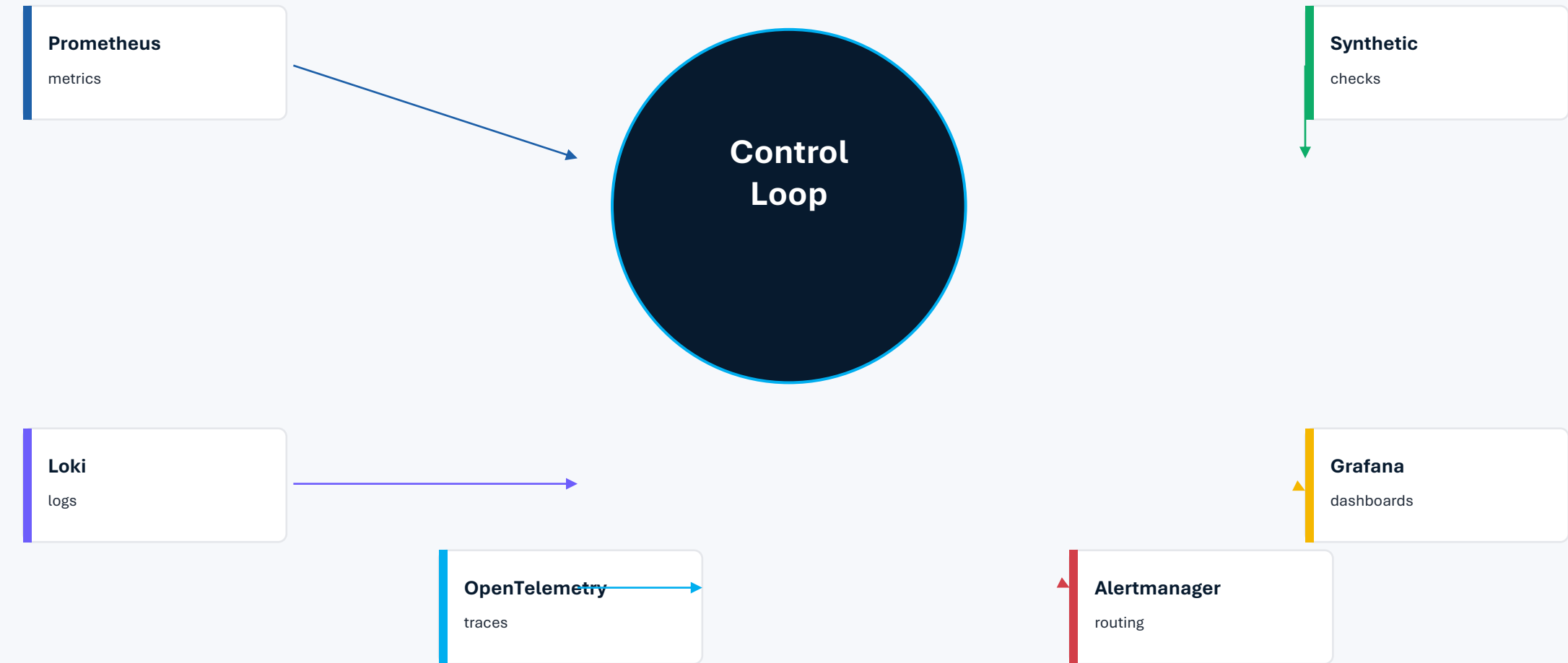
Promotion gates

Dev → Staging	build, unit tests, SAST, image scan	automated
Staging → Pre-Prod	integration, contract, DAST, SBOM, performance	Tech Lead + QA
Pre-Prod → Prod	UAT, compliance, DB validation, blackout check	Release Manager + SRE Lead

No environment-specific branches. Secrets come from approved secret manager. ArgoCD detects configuration drift.

Observability and DORA Metrics

Runtime and pipeline telemetry drive rollback, governance and improvement



DORA targets

Deployment frequency: multiple/day • Lead time: <2h • Change failure rate: <5% • MTTR: <15m

Incident Simulation: Friday 5:07 PM IST

Scenario validates rollback, communication and control design under pressure

Simultaneous alerts

HTTP 500 rate: 12%
PostgreSQL pool exhausted
Payment gateway timeout: 35%

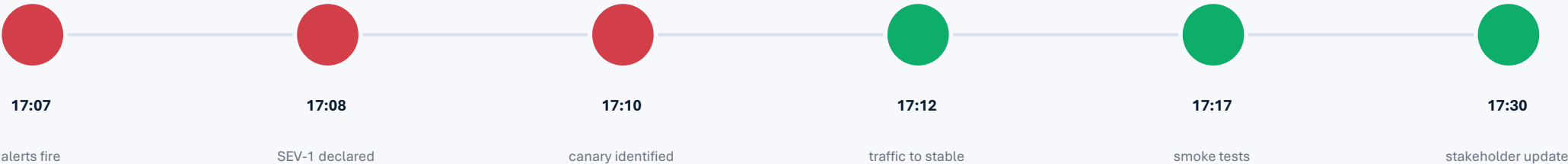
Severity

SEV-1: payment/customer-impacting production degradation during peak window

Root control gap

Critical hotfix bypassed staging and production promotion governance

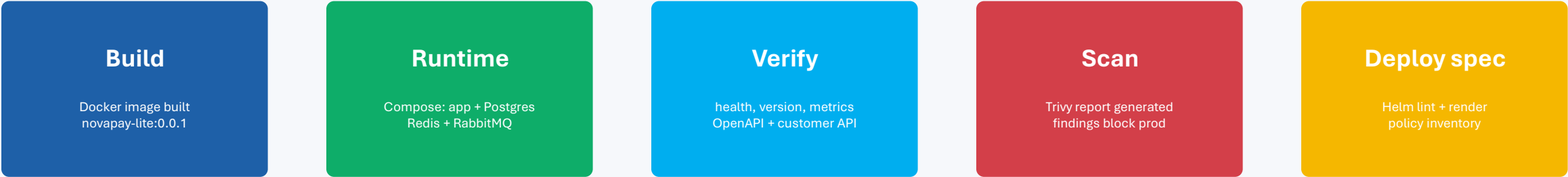
Response timeline



Decision: set canary to 0%, restore stable to 100%, freeze release, preserve evidence, start postmortem.

Local Evidence from NovaPay Lite

The sample app is a pipeline target, not the project deliverable



Evidence files

docker-build.txt, docker-image-inspect.json
trivy-image-report.txt
docker-compose-ps.txt
health-endpoint.txt, version-endpoint.json, prometheus-metrics.txt
customer-api-response.txt, customer-db-row.txt
helm-lint.txt, helm-rendered.yaml

Audit interpretation

Local Trivy findings are evidence that the scan ran. In production, Critical/High findings block promotion or require approved exception.

Local evidence demonstrates pipeline mechanics; regulated controls are documented in the architecture and runbooks.

Risk Register and Mitigations

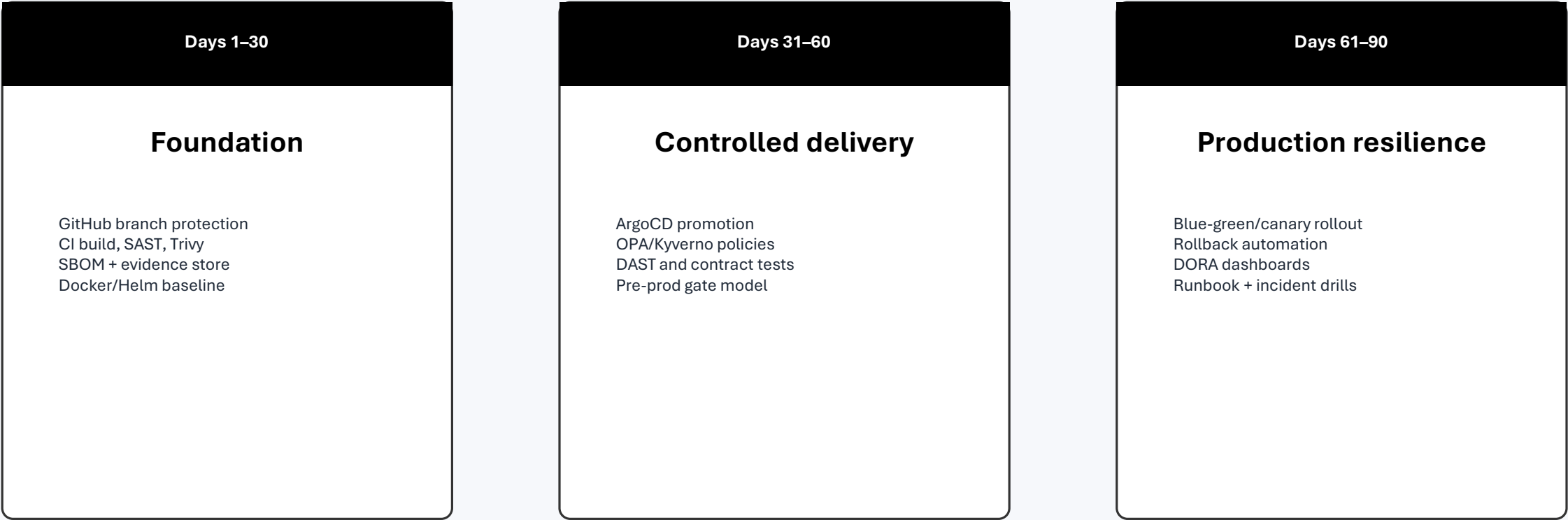
TRC focus: residual risk is explicit, owned and controlled

Risk	Impact	Mitigation
Critical CVEs in image	Unsafe release if allowed to promote	Trivy gate blocks production; remediation or exception required
DB contract migration	Irreversible break or data loss	Separate change, DBA/CAB approval, backup and validation
Gate friction	Developer bypass pressure	Fast feedback, parallel stages, clear exception process
Rollback automation failure	Longer MTTR during incident	Warm rollback target + manual runbook fallback
No live cluster yet	Evidence remains local/demo level	Target architecture defines Kubernetes/ArgoCD implementation path
Policy drift	Production config diverges from approved state	GitOps drift detection + OPA/Kyverno admission control

Residual risk posture: acceptable for TRC approval when implementation roadmap and evidence controls are funded.

90-Day Implementation Roadmap

Move from design to controlled production rollout in three implementation waves



Exit criteria: production release path has signed artefacts, enforced gates, canary/blue-green rollout, rollback evidence and DORA reporting.

TRC Approval Ask

Approve NovaPay's regulated delivery platform as the control framework for production change.

1

Approve target architecture

8-stage DevSecOps pipeline with compliance gates and evidence packs

2

Approve implementation roadmap

90-day staged rollout with production controls and incident drills

3

Approve governance model

Dual approval, SoD, risk exceptions and automated rollback authority

Decision criteria

Faster releases
Lower MTTR
Complete evidence
Regulatory confidence

Recommended TRC decision: APPROVE controlled implementation with monthly risk review.